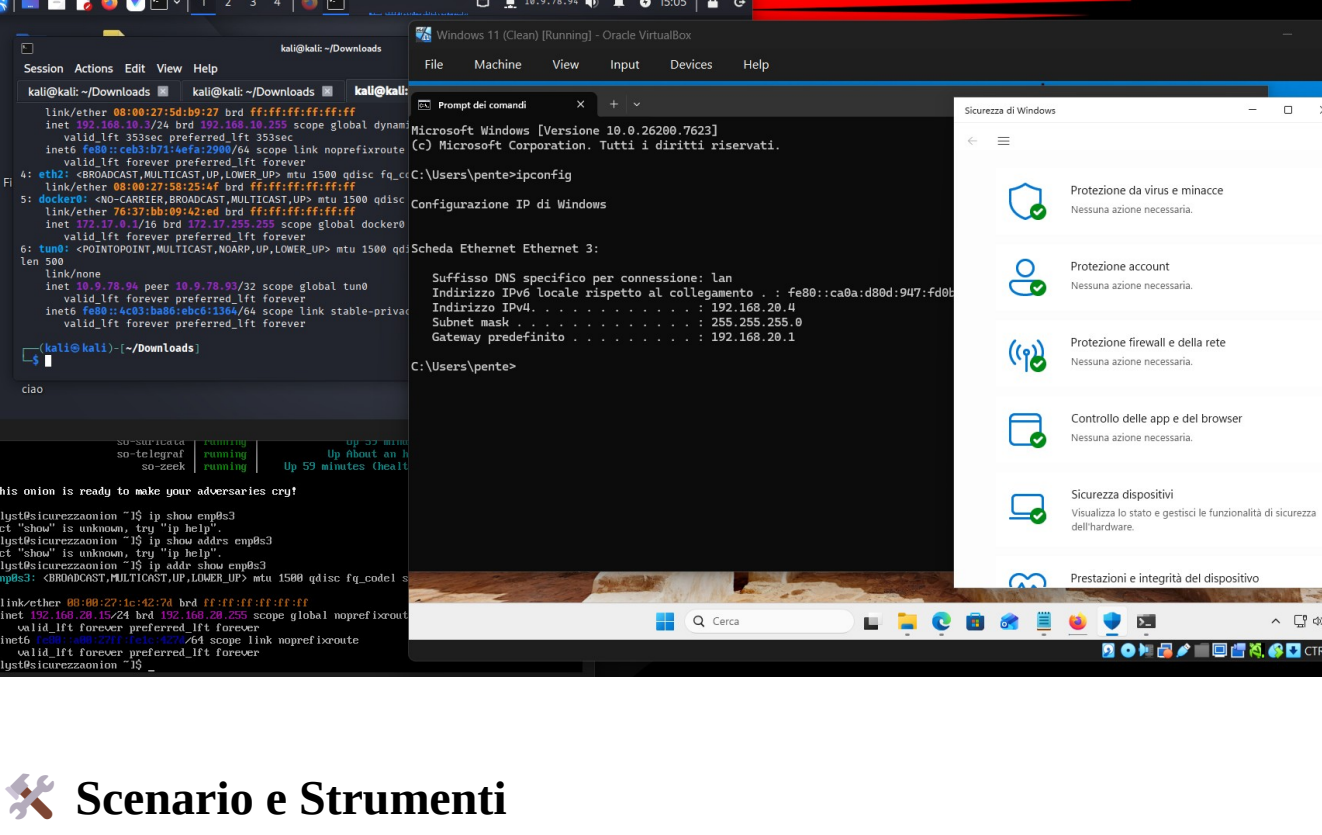


DNS Spoofing

Panoramica del Progetto

Questo laboratorio documenta un vettore d'attacco avanzato che sfrutta la manipolazione del **Certificate Store** di Windows 11 e l'iniezione di configurazioni proxy per intercettare, decifrare e sottrarre dati sensibili (credenziali e cookie di sessione) da una vittima ignara.



Scenario e Strumenti

- **Vittima:** Windows 11 (build 26100.2605) con Microsoft Defender attivo.
- **Attaccante:** Kali Linux con framework ... per l'intercettazione SSL/TLS
- **Altro:** File Scripting, Tunnel(per simulare attacco da rete esterna)

Fasi dell'Attacco

1. Infiltrazione e Manipolazione del Sistema

L'attacco inizia con l'esecuzione dello script **dns.bat**. Grazie all'affidabilità percepita di piattaforme come GitHub, l'utente viene indotto a scaricare ed eseguire il payload.

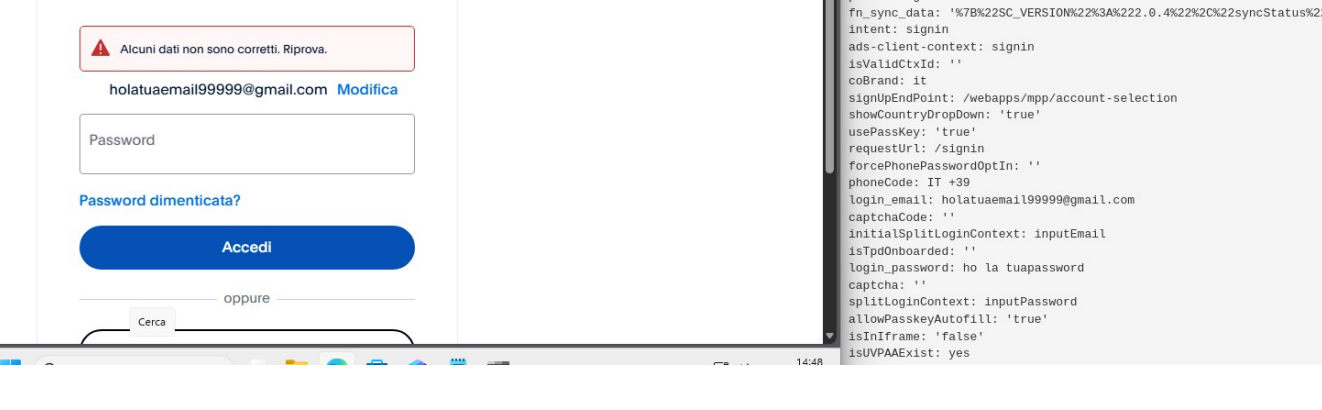
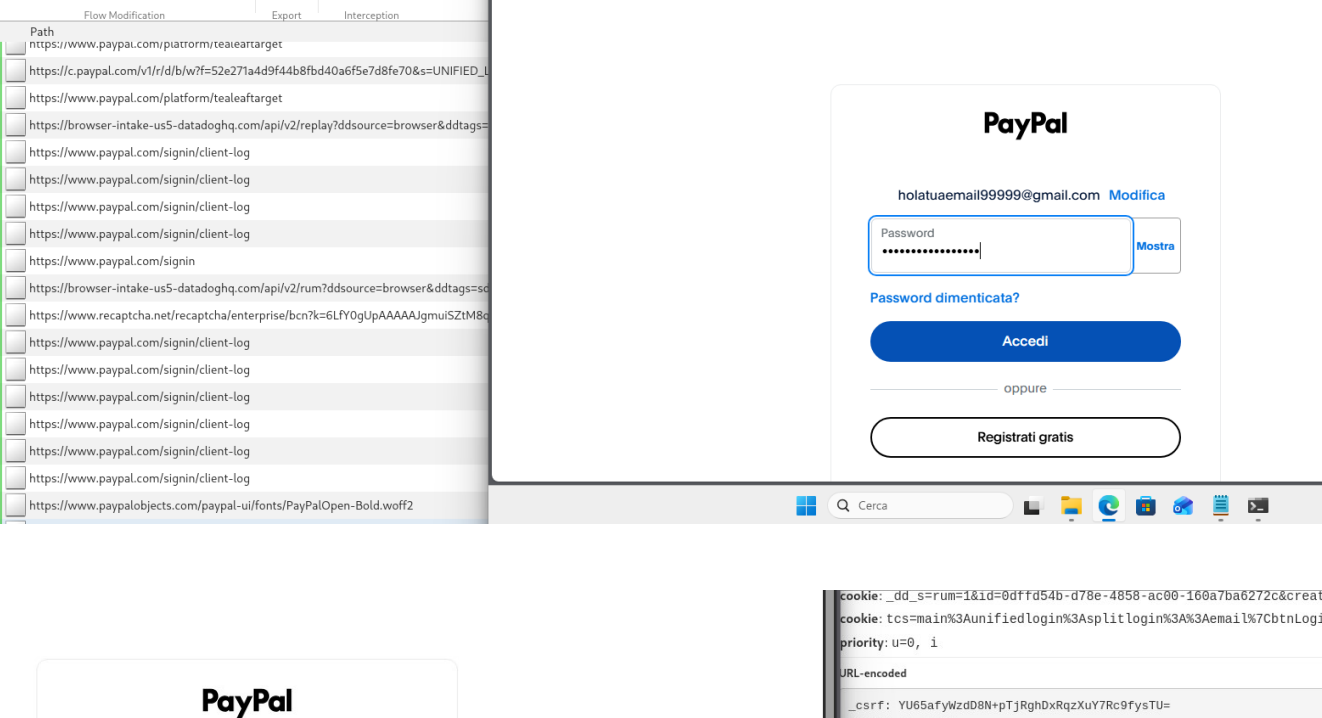


- **Installazione CA Falsa:** Lo script DNS scarica un certificato Root non autorizzato e lo installa forzatamente nel magazzino dei certificati affidabili di Windows.
- **Proxy Setup:** Vengono modificate le chiavi di registro per reindirizzare tutto il traffico web (porte 80/443) verso l'indirizzo dell'attaccante.
- **Ripristino:** Lo script puliziaDNS ripristina la macchina dall'attacco

2. Intercettazione e SSL Hijacking

Con il certificato malevolo installato, i browser che si appoggiano allo store di sistema (**Google Chrome** e **Microsoft Edge**) riconoscono come "sicure" le connessioni intercettate dall'attaccante.

- **Cattura Credenziali:** Durante il login su piattaforme come **PayPal**, l'email (holatuaemai199999@gmail.com) e la password vengono catturate in chiaro nella dashboard di mitmproxy.
- **Analisi dei Flussi:** L'attaccante ha visibilità completa su tutti i percorsi (path) e le chiamate API effettuate dal browser della vittima.



3. Furto dei Cookie e Bypass MFA

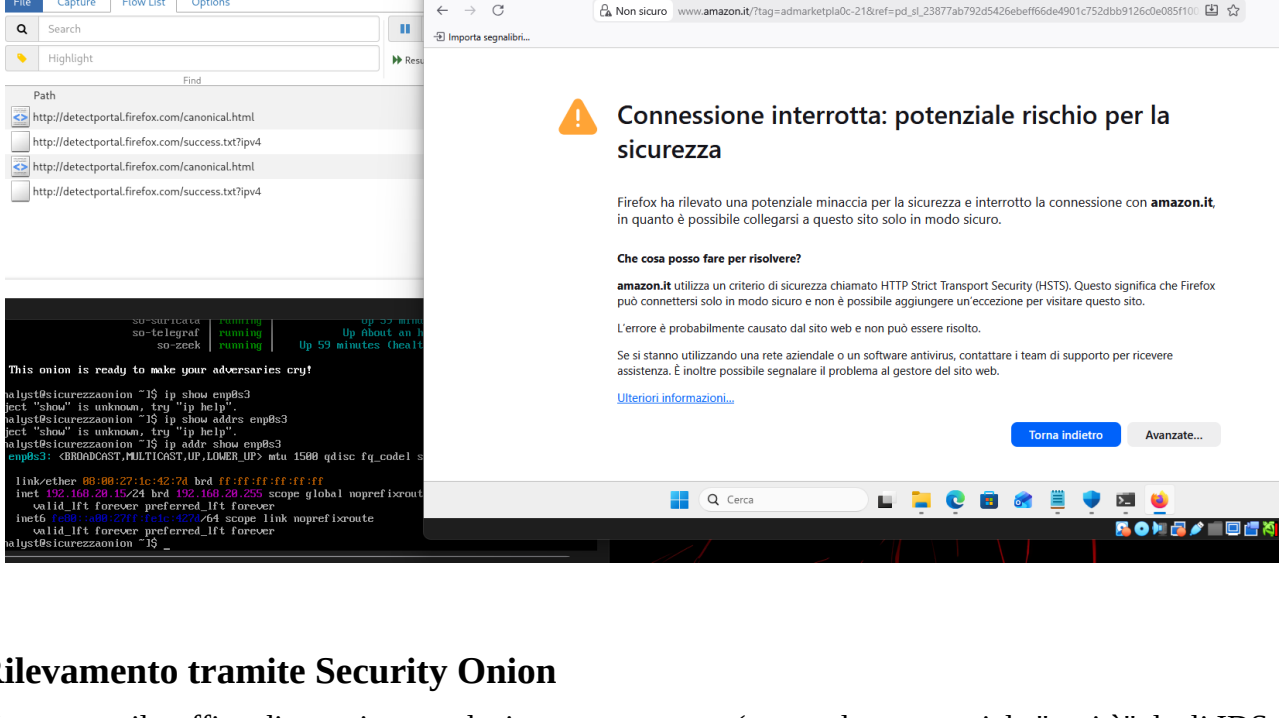
L'aspetto più critico è il furto dei **Cookie di Sessione**.

- **Oltre la Password:** Catturando i cookie dopo un login andato a buon fine, l'attaccante può clonare la sessione attiva.
- **Bypass 2FA:** Poiché il cookie viene generato *dopo* che l'utente ha inserito il codice di sicurezza (MFA), l'attaccante che utilizza quel cookie risulta già autenticato per il server, rendendo inutile la protezione a due fattori.

Analisi della Difesa (Blue Team)

Differenze tra Browser

- **Chrome/Edge:** Vulnerabili, poiché accettano i certificati installati nel sistema operativo.
- **Mozilla Firefox:** Ha bloccato l'attacco. Firefox utilizza un proprio database di certificati interno e ha rilevato la firma non valida, emettendo un avviso di "Connessione interrotta: potenziale rischio".

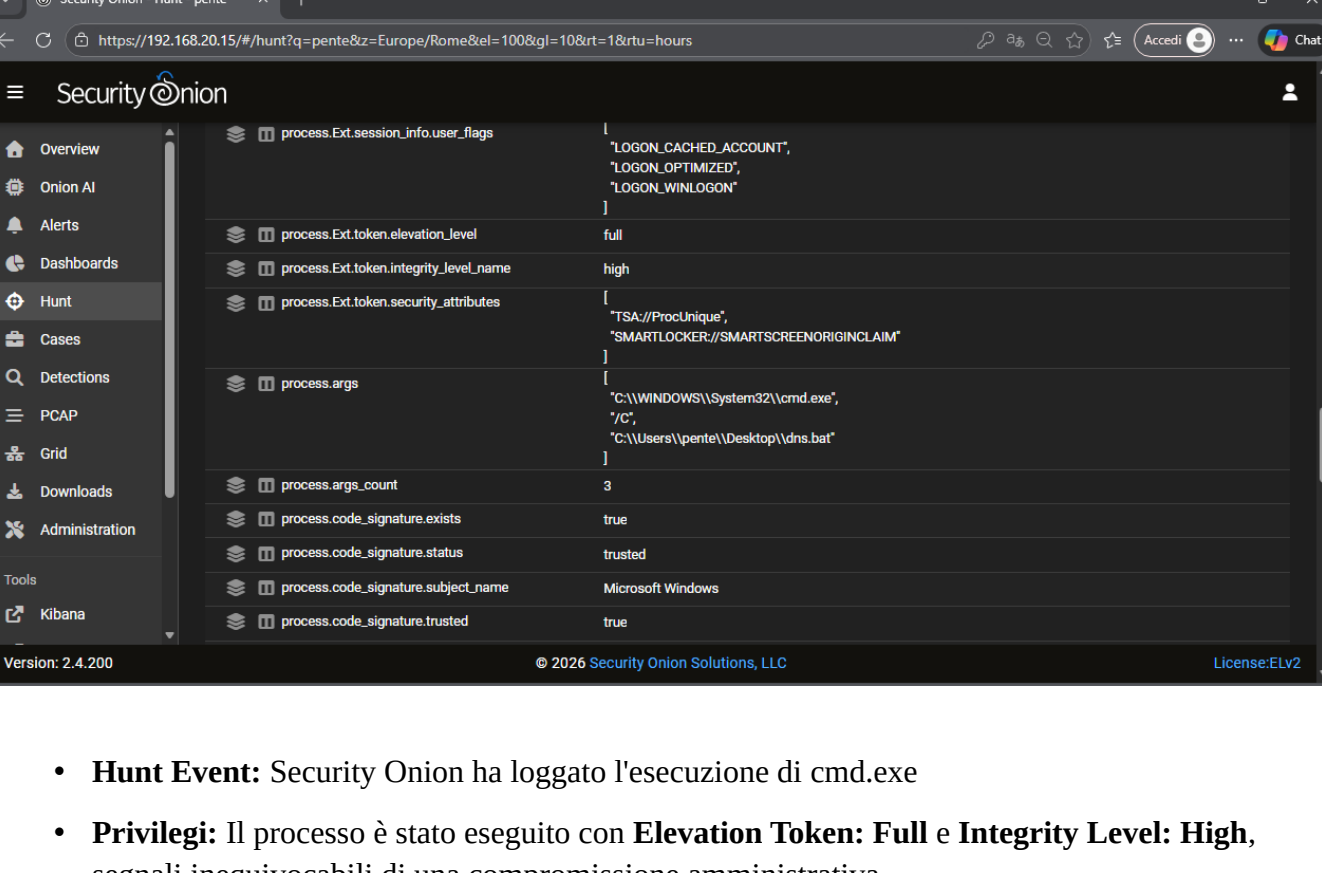


Rilevamento Security Onion

Nonostante il traffico di rete sia stato deviato con successo (causando una parziale "cecità" degli IDS di rete),



la telemetria degli endpoint ha registrato l'attività sospetta dopo aver lanciato il comando di puliziaDNS:



- **Hunt Event:** Security Onion ha loggato l'esecuzione di cmd.exe
- **Privilegi:** Il processo è stato eseguito con **Elevation Token: Full** e **Integrity Level: High**, segnali inequivocabili di una compromissione amministrativa.

Conclusioni

L'esperienza dimostra che la fiducia del browser verso l'integrità del sistema operativo è un punto di vulnerabilità critico. Un utente standard, vedendo il simbolo del lucchetto (HTTPS) su Edge o Chrome, non sospetterebbe mai che la propria sessione sia monitorata.

Rischi rilevati:

1. **Account Takeover** totale tramite Session Hijacking.
2. Incapacità dell'MFA di proteggere sessioni già stabilite.
3. Necessità di monitoraggio costante dei registri di sistema e dell'installazione di nuovi certificati Root.

⚠ **Nota sulla fattibilità reale:** Sebbene in questo scenario di test i file utilizzati possano risultare identificabili, è cruciale comprendere che in un attacco reale la pericolosità aumenterebbe esponenzialmente. Un attaccante esperto, utilizzando tecniche avanzate di Ingegneria Sociale, potrebbe camuffare il file batch (es. convertendolo in un eseguibile con icone legittime, firmandolo digitalmente o nascondendolo fra "crackato"). In tali condizioni, senza strumenti di analisi comportamentale o un occhio estremamente esperto, l'attacco risulterebbe estremamente difficile da evitare.